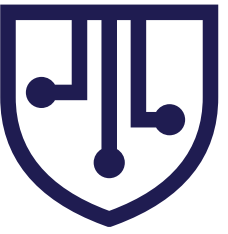


CSS6224 NETWORK SECURITY

An abstract digital network visualization. It features a dark blue background with numerous glowing blue nodes of varying sizes. These nodes are interconnected by a complex web of thin, light blue lines. On the left side, a series of parallel lines fan out towards the center, suggesting a data stream or a specific network topology. The overall effect is one of high-tech connectivity and data flow.

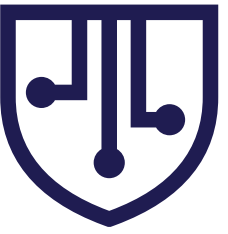
Lecture 12: Electronic Mail Security



Learning Objectives

After studying this chapter, you should be able to:

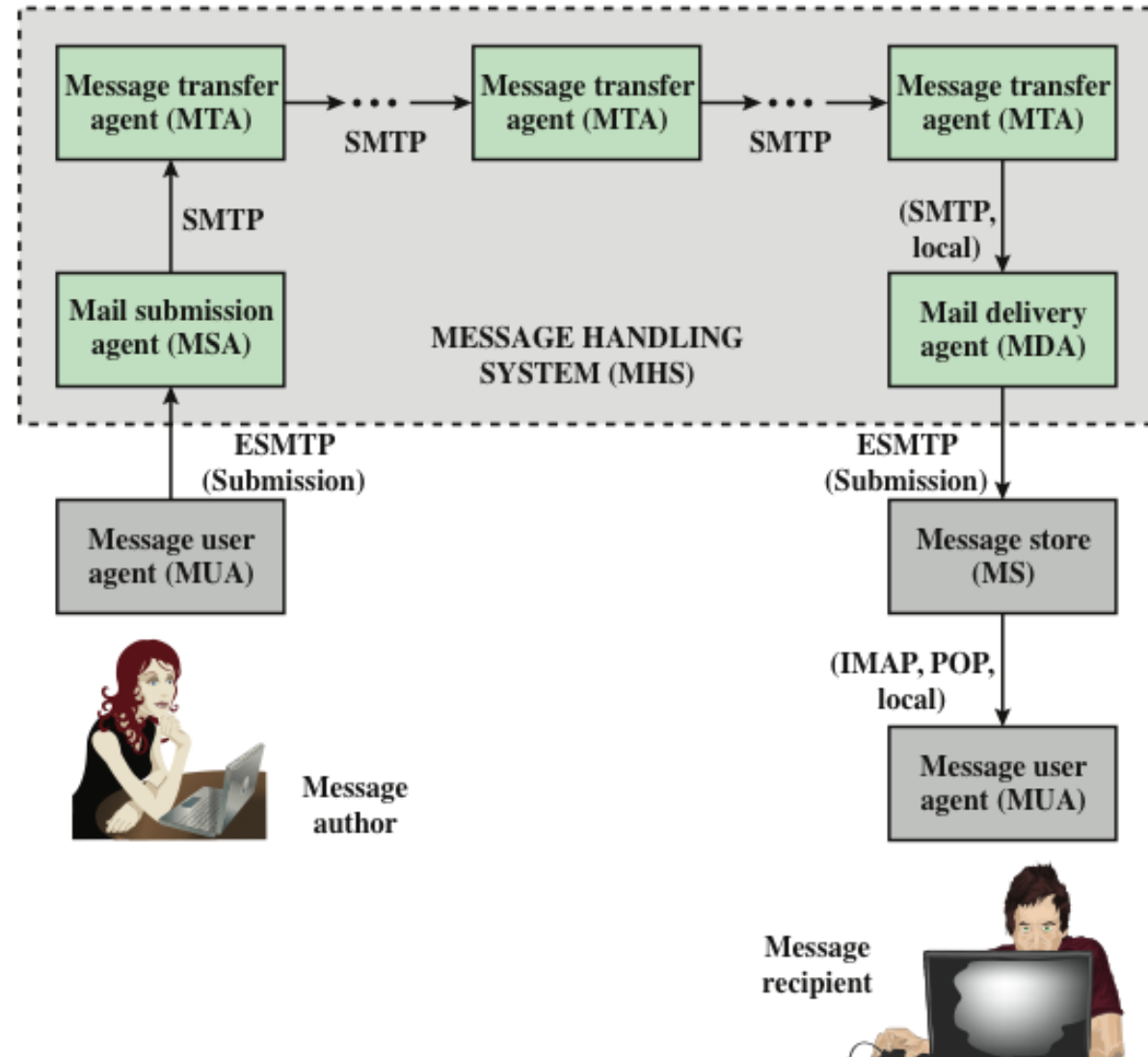
- Summarize the key functional components of the Internet mail architecture.
- Explain the basic functionality of SMTP, POP3, and IMAP.
- Explain the need for MIME as an enhancement to ordinary e-mail.
- Describe the key elements of MIME.
- Understand the functionality of S/MIME and the security threats it addresses.
- Understand the basic mechanisms of STARTTLS and its role in e-mail security.

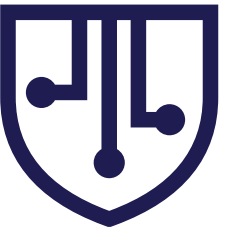


Internet Mail Architecture

- Defined in RFC 5598 (**Internet Mail Architecture**, July 2009)
- E-mail components:
 - At its most fundamental level, the internet mail architecture consists of a user world in the form of Message User Agents (MUA)
 - And the transfer world, in the form of the Message Handling Service (MHS), which is composed of Message Transfer Agents (MTA)
 - The MHS accepts a message from one user and delivers it to one or more other users, creating a virtual MUA-to-MUA exchange environment
 - This architecture involves three types of interoperability

Function Modules and Standardized Protocols Used Between Them in the Internet Mail Architecture

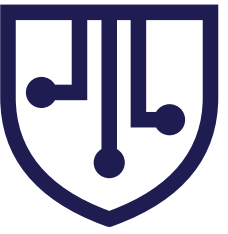




E-Mail Components

- Administrative management domain (ADMD)
 - Internet e-mail provider
 - Examples include a department that operates a local mail relay, an IT department that operates an enterprise mail relay, and an ISP that operates a public shared e-mail service
 - Each ADMD can have different operating policies and trust-based decision making
- Domain name system (DNS)
 - A directory lookup service that provides a mapping between the name of a host on the Internet and its numerical address





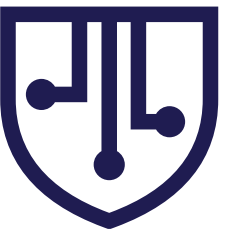
E-Mail Protocols SMTP

- Simple Mail Transfer Protocol (SMTP)
 - Encapsulates an e-mail message in an envelope and is used to relay the encapsulated messages from source to destination through multiple MTAs
 - Is a text-based client-server protocol where the client (e-mail sender) contacts the server (next-hop recipient) and issues a set of commands to tell the server about the message to be sent, then sending the message itself



Figure 8.2 Example SMTP Transaction Scenario

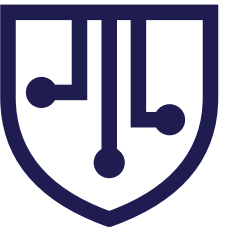
```
S: 220 foo.com Simple Mail Transfer Service Ready
C: HELO bar.com
S: 250 OK
C: MAIL FROM:<Smith@bar.com>
S: 250 OK
C: RCPT TO:<Jones@foo.com>
S: 250 OK
C: RCPT TO:<Green@foo.com>
S: 550 No such user here
C: RCPT TO:<Brown@foo.com>
S: 250 OK
C: DATA
S: 354 Start mail input; end with <CRLF>.<CRLF>
C: Blah blah blah...
C: ...etc. etc. etc.
C: <CRLF><CRLF>
S: 250 OK
C: QUIT
S: 221 foo.com Service closing transmission channel
```



Mail Access Protocols (1 of 2)

Post Office Protocol (POP3)

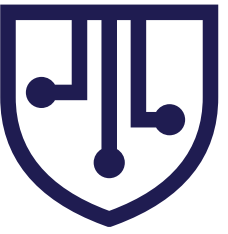
- Allows an e-mail client (user agent) to download an e-mail from an e-mail server (MTA)
- POP3 user agents connect via TCP to the server (usually port 110)
- The user agent enters a username and password
- After authorization, the UA can issue POP3 commands to retrieve and delete mail



Mail Access Protocols (2 of 2)

Internet Mail Access Protocol (IMAP)

- Enables an e-mail client to access mail on an e-mail server
- Uses TCP, with server TCP port 143
- Is more complex than POP3
- Provides stronger authentication than POP3 and provides other functions not supported by POP3

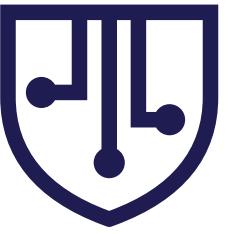


E-Mail Formats (1 of 2)

- RFC 5322
 - Defines a format for text messages that are sent using electronic mail
 - Has been the standard for Internet-based text mail messages
 - Messages are viewed as having an envelope and contents
 - The envelope contains whatever information is needed to accomplish transmission and delivery
 - The contents compose the object to be delivered to the recipient

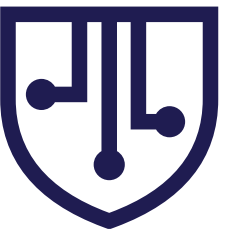
E-Mail Formats (2 of 2)

- Multipurpose Internet Mail Extensions (MIME)
 - Extension to the RFC 5322 framework
 - RFCs 2045 through 2049 define MIME
 - Five new message header fields are defined, which may be included in an RFC 5322 header, providing information about the body of the message
 - A number of content formats are defined, thus standardizing representations that support multimedia electronic mail
 - Transfer encodings are defined that enable the conversion of any content format into a form that is protected from alteration by the mail system



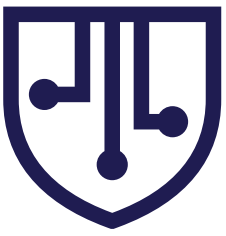
Header Fields Defined in MIME

- **MIME-Version:** This field indicates that the message conforms to RFCs 2045 and 2046
- **Content-Type:** Describes the data contained in the body with sufficient detail that the receiving user agent can pick an appropriate agent or mechanism to represent the data to the user or otherwise deal with the data in an appropriate manner
- **Content-Transfer-Encoding:** Indicates the type of transformation that has been used to represent the body of the message in a way that is acceptable for mail transport
- **Content-ID:** Used to identify MIME entities uniquely in multiple contexts
- **Content-Description:** A text description of the object with the body



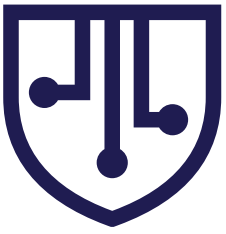
E-Mail Threats

- E-mail security threats can be classified as:
 1. **Authenticity-related threats:** Could result in unauthorized access to an enterprise's e-mail system
 2. **Integrity-related threats:** Could result in unauthorized modification of e-mail content
 3. **Confidentiality-related threats:** Could result in unauthorized disclosure of sensitive information
 4. **Availability-related threats:** Could prevent end users from being able to send or receive e-mail



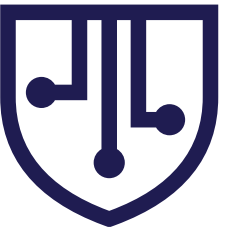
Email Threats and Mitigations (1 of 2)

Threat	Impact on Purported Sender	Impact on Receiver	Mitigation
Email sent by unauthorized MTA in enterprise (e.g. malware botnet)	Loss of reputation, valid email from enterprise may be blocked as possible spam/phishing attack.	UBE and/or email containing malicious links may be delivered into user inboxes	Deployment of domain-based authentication techniques. Use of digital signatures over email.
Email message sent using spoofed or unregistered sending domain	Loss of reputation, valid email from enterprise may be blocked as possible spam/phishing attack.	UBE and/or email containing malicious links may be delivered into user inboxes	Deployment of domain-based authentication techniques. Use of digital signatures over email.
Email message sent using forged sending address or email address (i.e. phishing, spear phishing)	Loss of reputation, valid email from enterprise may be blocked as possible spam/phishing attack.	UBE and/or email containing malicious links may be delivered. Users may inadvertently divulge sensitive information or PII.	Deployment of domain-based authentication techniques. Use of digital signatures over email.
Email modified in transit	Leak of sensitive information or PII.	Leak of sensitive information, altered message may contain malicious information	Use of TLS to encrypt email transfer between server. Use of end-to-end email encryption.



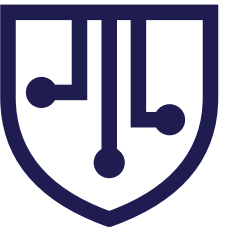
Email Threats and Mitigations (2 of 2)

Threat	Impact on Purported Sender	Impact on Receiver	Mitigation
Disclosure of sensitive information via monitoring and capturing of email traffic	Leak of sensitive information or PII.	Leak of sensitive information, altered message may contain malicious information	Use of TLS to encrypt email transfer between server. Use of end-to-end email encryption.
Unsolicited Bulk Email (i.e. spam)	None, unless purported sender is spoofed.	UBE and/or email containing malicious links may be delivered into user inboxes	Techniques to address UBE
DoS/DDoS attack against an enterprises' email servers	Inability to send email.	Inability to receive email.	Multiple mail servers, use of cloud-based email providers.



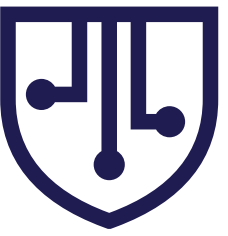
S/MIME

- Secure/Multipurpose Internet Mail Extension
- Is a security enhancement to the MIME Internet e-mail format standard based on technology from RSA Data Security
- S/MIME is a complex capability that is defined in a number of documents



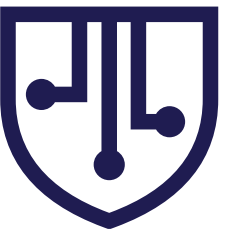
Summary of S/MIME Services

Function	Typical Algorithm	Typical Action
Digital signature	RSA/SHA-256	A hash code of a message is created using SHA-256. This message digest is encrypted using SHA-256 with the senders private key and included with the message.
Message encryption	AES- 128 with CBC	A message is encrypted using AES-128 with CBC with a one-time session key generated by the sender. The session key is encrypted using RSA with the recipient's public key and included with the message.
Compression	unspecified	A message may be compressed for storage or transmission.
E-mail compatibility	Radix-64 conversion	To provide transparency for e-mail applications, an encrypted message may be converted to an ASCII string using radix-64 conversion.



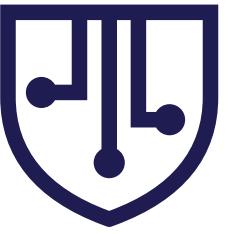
Authentication

- Authentication is provided by means of a digital signature
 - Most commonly RSA with SHA-256 is used
 - The sender creates a message
 - SHA-256 is used to generate a 256-bit message digest of the message
 - The message digest is encrypted with RSA using the sender's private key, and the result is appended to the message; also appended is identifying information for the signer, which will enable the receiver to retrieve the signer's public-key
 - The receiver uses RSA with the sender's public key to decrypt and recover the message digest
 - The receiver generates a new message digest for the message and compares it with the decrypted hash code; if the two match, the message is accepted as authentic

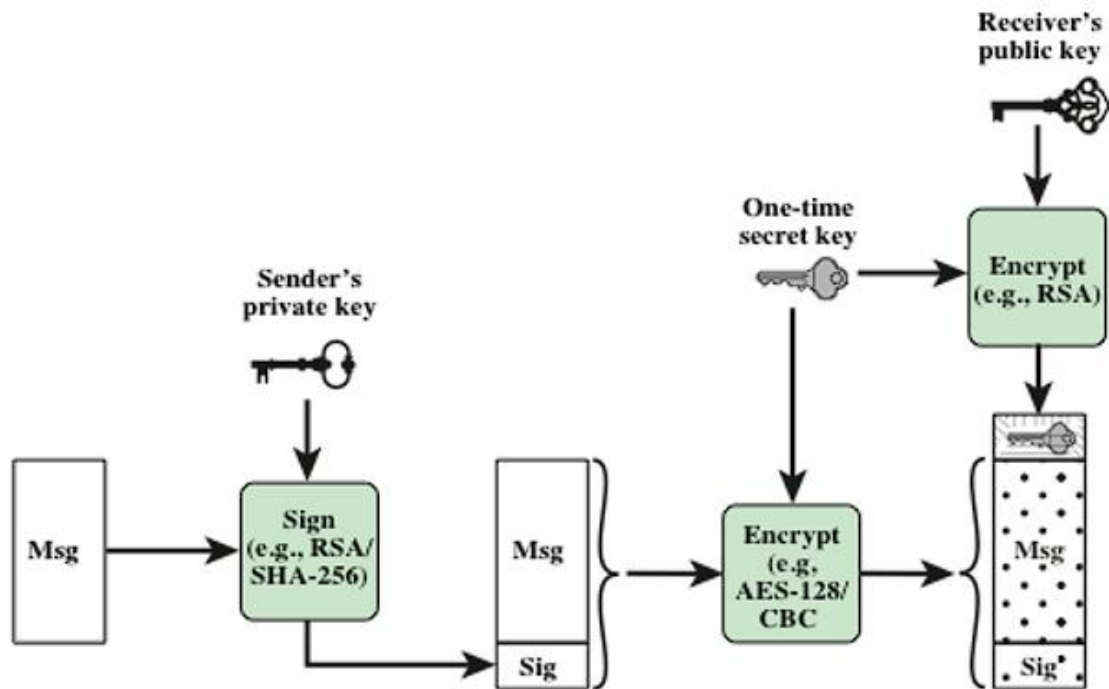


Confidentiality

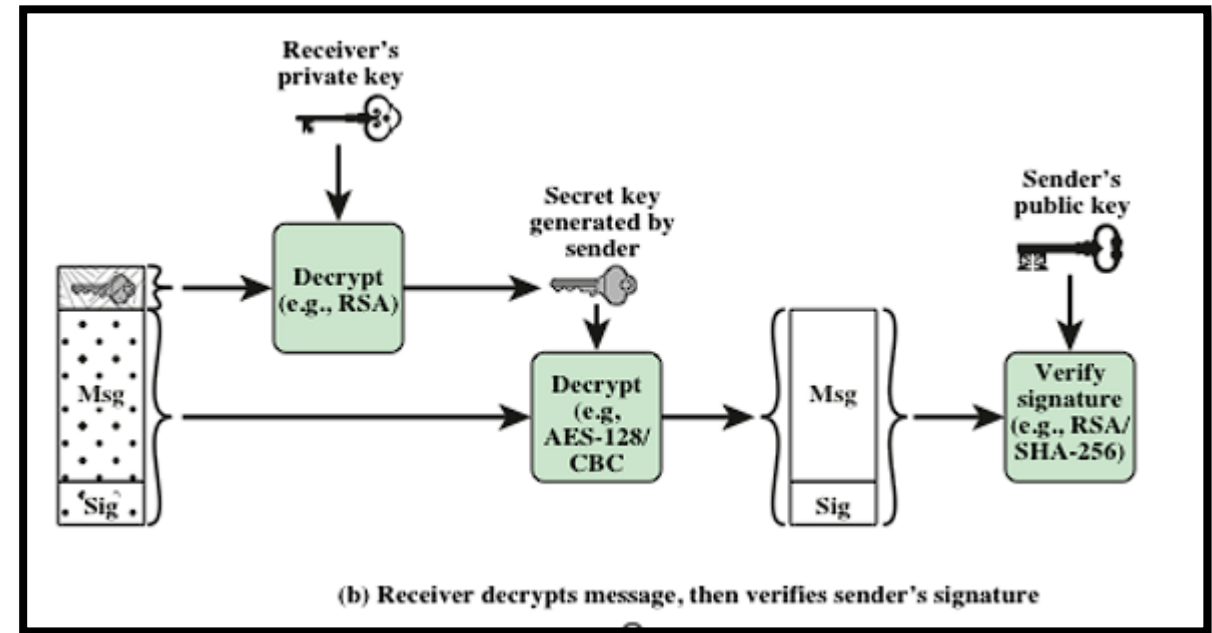
- S/MIME provides confidentiality by encrypting messages
- Most commonly AES with a 128-bit key is used, with the cipher block chaining (CBC) mode
- The key itself is also encrypted, typically with RSA
- In S/MIME each symmetric key, referred to as a content-encryption key, is used only once
- To protect the key, it is encrypted with the receiver's public key
- Sequence:
 - The sender generates a message and a random 128-bit number to be used as a content-encryption key for this message only
 - The message is encrypted using the content-encryption key
 - The content-encryption key is encrypted with RSA using the recipient's public key and is attached to the message
 - The receiver uses RSA with its private key to decrypt and recover the content-encryption key
 - The content-encryption key is used to decrypt the message



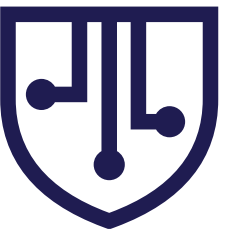
Simplified S/MIME Functional Flow



(a) Sender signs, then encrypts message



(b) Receiver decrypts message, then verifies sender's signature



E-mail Compatibility

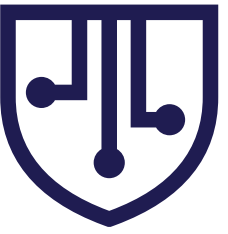
- Many electronic mail systems only permit the use of blocks consisting of ASCII text
- To accommodate this restriction, S/MIME provides the service of converting the raw 8-bit binary stream to a stream of printable ASCII characters
 - A process referred to as 7-bit encoding
- The scheme typically used for this purpose is Base64 conversion
 - Each group of three octets of binary data is mapped into four ASCII characters





Compression

- S/MIME also offers the ability to compress a message
 - This has the benefit of saving space both for e-mail transmission and for file storage
- Compression can be applied in any order with respect to the signing and message encryption operations
- RFC 5751 provides the following guidelines:
 - Compression of binary encoded encrypted data is discouraged, since it will not yield significant compression; Base64 encrypted data could very well benefit, however
 - If a lossy compression algorithm is used with signing, you will need to compress first, then sign



S/MIME Message Content Types

- **Data:** Refers to the inner MIME-encoded message content, which may then be encapsulated in a SignedData, EnvelopedData, or CompressedData content type
- **SignedData:** Used to apply a digital signature to a message
- **EnvelopedData:** This consists of encrypted content of any type and encrypted-content encryption keys for one or more recipients
- **CompressedData:** Used to apply data compression to a message



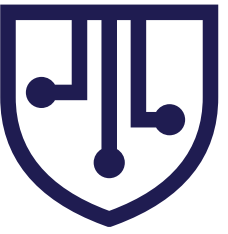
Cryptographic Algorithms Used in S/MIME

Function	Requirement
Create a message digest to be used in forming a digital signature.	Must support SHA-256 Should support SHA-1 Receiver Should support M D5 for backward compatibility
Use message digest to form a digital signature.	Must support RSA with SHA-256 Should support • D S A with SHA-256 • RSA S S A.P S S with SHA-256 • RSA with SHA-1 • D S A with SHA-1 • RSA with M D S
Encrypt session key for transmission with a message.	Must support RSA encryption Should support • RSAES-O A E P • Diffie-Hellman ephemeral-static mode
Encrypt message for transmission with a one-time session key.	Must support AES-128 with CBC Should support • AES-192 CBC and AES-256 CBC • Triple DES CBC



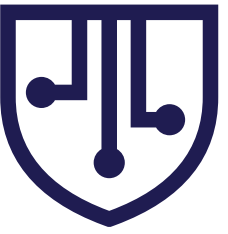
S/MIME Certificate Processing

- A S/MIME user has several key management functions to perform:
 - **Key generation:** The user of some related administrative utility Must be capable of generating separate Diffie-Hellman and DSS key pairs and Should be capable of generating RSA key pairs
 - **Registration:** A user's public key must be registered with a certification authority in order to receive an X.509 public-key certificate
 - **Certificate storage and retrieval:** A user requires access to a local list of certificates in order to verify incoming signatures and to encrypt outgoing messages



Enhanced Security Services

- RFC 2634 defines four enhanced security services for S/M I M E:
 - Signed receipts
 - Security labels
 - Secure mailing lists
 - Signing certificates



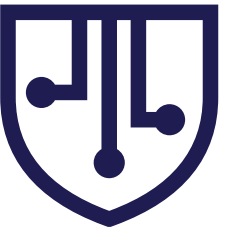
Pretty Good Privacy (PGP)

- An alternative e-mail security protocol
- Has essentially the same functionality as S/MIME
- Created by Phil Zimmerman and implemented as a product first released in 1991
- It was made available free of charge and became quite popular for personal use
- The initial PGP protocol was proprietary and used some encryption algorithms with intellectual property restriction
- There are two significant differences between S/MIME and OpenPGP:
 1. Key certification
 2. Key distribution
- SP 800-177 recommends the use of S/MIME rather than PGP because of the greater confidence in the CA system of verifying public keys



S/MIME VS PGP

Feature	S/MIME	PGP
Origin	Developed by RSA Data Security	Developed by Phil Zimmermann
Standardization	IETF standard (RFC 5751)	OpenPGP (RFC 4880)
Key Management	Centralized (uses X.509 certificates with CA)	Decentralized (Web of Trust model)
Encryption Algorithm	Typically RSA or ECC for key exchange, AES for data	RSA, DSA/ElGamal, ECC (OpenPGP), AES for data
Digital Signature	Yes, based on X.509 certificates	Yes, based on user-generated key pairs
Certificate Authority (CA)	Required; relies on trusted CAs	Not required; trust is managed by users
Ease of Use	Easier in enterprise settings (e.g., Outlook, Exchange)	More user-controlled; less intuitive for new users
Compatibility	Widely supported in enterprise email clients	Supported in many email clients with plugins
Trust Model	Hierarchical (PKI-based)	Decentralized (Web of Trust or direct trust)
Primary Use Case	Corporate/Enterprise email security	Personal or open-source email security
Security Level	High, with strong organizational control	High, with strong user autonomy
Integration	Built into Outlook, Apple Mail, etc.	Requires additional setup or plugins



Domain Name System (DNS)

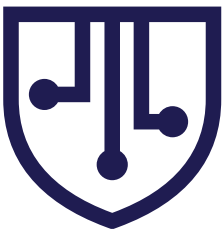
- A directory lookup service that provides a mapping between the name of a host on the Internet and its numeric IP address
- Is essential to the functioning of the Internet
- Is used by MUAs and MTAs to find the address of the next hop server for mail delivery
- Comprised of four elements:
 - i. Domain name space:** D N S uses a tree-structured name space to identify resources on the Internet
 - ii. DNS database:** each node and leaf in the name space tree structure names a set of information that is contained in resource record (RRs)
 - iii. Name servers:** server programs that hold information about a portion of the domain name tree structure and the associated RRs
 - iv. Resolvers:** programs that extract information from name servers in response to client requests



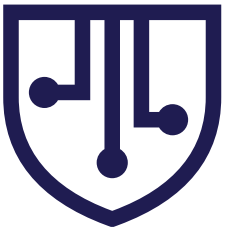
DNS Security Extensions

- DNSSEC:
 - Provides end-to-end protection through the use of digital signatures that are created by responding zone administrators and verified by a recipient's resolver software
 - Avoids the need to trust intermediate name servers and resolvers that cache or route the DNS records originating from the responding zone administrator before they reach the source of the query
 - Consists of a set of new resource record types and modifications to the existing DNS protocol
- Defined in:
 - RFC 4033, **DNS Security Introduction and Requirements**
 - RFC 4034, **Resource Records for the DNS Security Extensions**
 - RFC 4035, **Protocol Modifications for the DNS Security Extensions**

DNS-Based Authentication of Named Entities (DANE)



- DANE is a protocol to allow X.509 certificates, commonly used for Transport Layer Security (TLS), to be bound to DNS names using DNSSEC
- It is proposed in RFC 6698 as a way to authenticate TLS client and server entities without a certificate authority (CA)
- The purpose of D A N E is to replace reliance on the security of the CA system with reliance on the security provided by DNSSEC
- DANE defines a new DNS record type, TLSA, that can be used for a secure method of authenticating SSL/TLS certificates



Sender Policy Framework (SPF)

- S P F is the standardized way for a sending domain to identify and assert the mail senders for a given domain
- Addresses the problem of any host being able to use any domain name for each of the various identifiers in the mail header, not just the domain name where the host is located
- Defined in RFC 7208
- S P F works by checking a sender's I P address against the policy encoded in any S P F record found at the sending domain

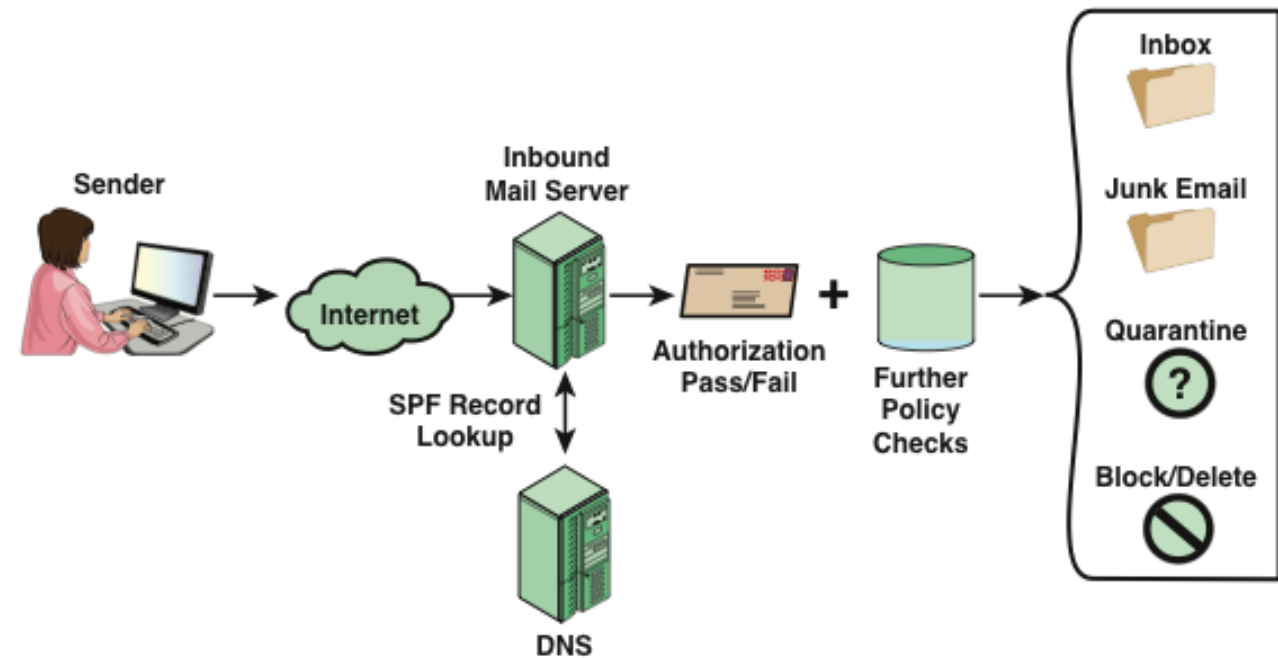
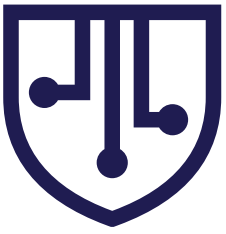


Figure 19.9 Sender Policy Framework Operation



DomainKeys Identified Mail (DKIM)

- **Email authentication method** designed to detect forged sender addresses in emails (email spoofing).
- It works by allowing the **sending domain** to attach a **digital signature** to outgoing messages, which can be verified by the **receiving email server**
- Message recipients can verify the signature by querying the signer's domain directly to retrieve the appropriate public key and can thereby confirm that the message was attested to by a party in possession of the private key for the signing domain
- Has been widely adopted by a range of e-mail providers and Internet Service Providers (ISPs)

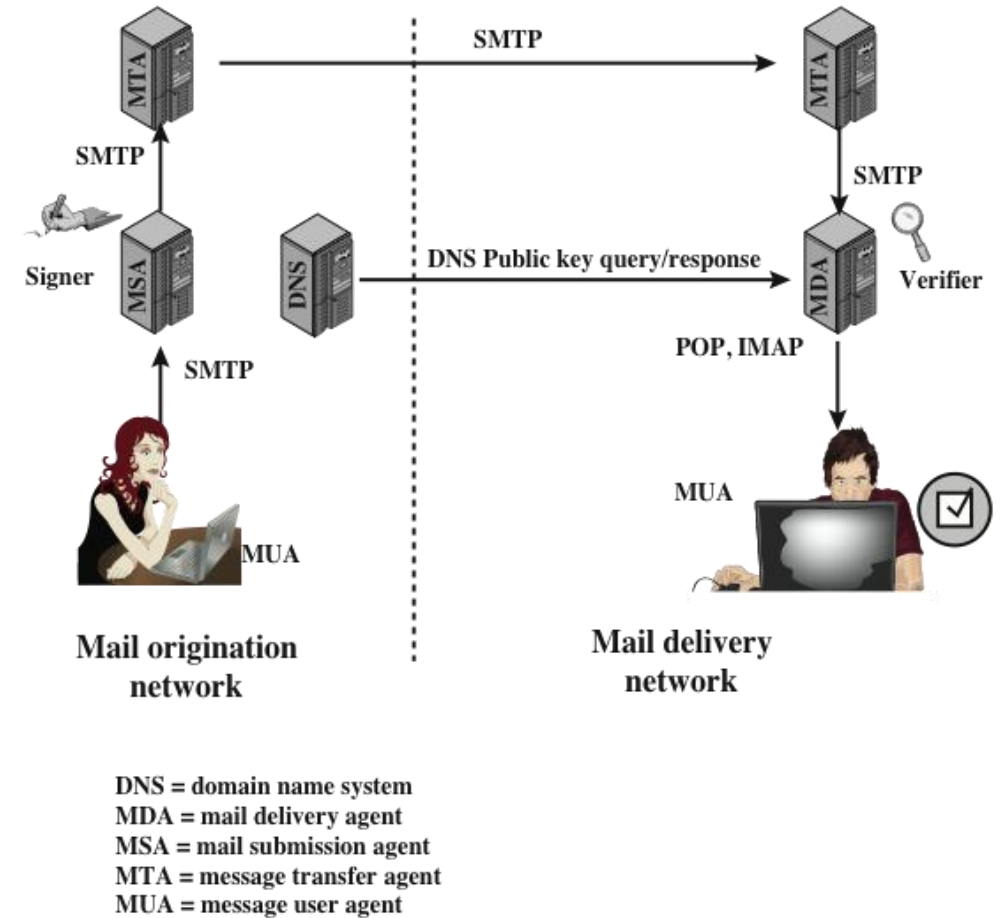
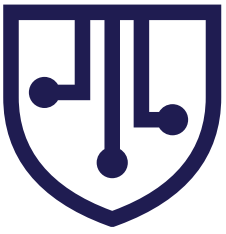


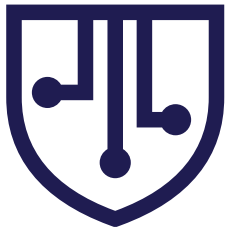
Figure 19.10 Simple Example of DKIM Deployment

DKIM STRATEGY



DKIM Strategy Element	Explanation
Authentication	Confirms the message was sent by an authorized server for the domain.
Message Integrity	Ensures the email content has not been tampered with during transit.
Domain Reputation Protection	Helps protect against domain spoofing, preserving sender credibility.
Spam & Phishing Reduction	Helps spam filters verify that emails are legitimate, reducing false negatives.
Part of DMARC Enforcement	DKIM is often used alongside SPF and DMARC to create a layered defense.
Selector Usage	Domains can use different selectors for various services (e.g., marketing vs. transactional email).
Key Rotation Policy	Periodic rotation of private/public keys enhances security.
Deployment with Third-Party Senders	DKIM signing should be set up for all authorized external mail services used by the domain.

Domain-Based Message Authentication, Reporting, and Conformance (DMARC)



- Allows email senders to specify policy on how their mail should be handled, the types of reports that receivers can send back, and the frequency those reports should be sent
- DMARC ensures that only authorized senders can send emails on behalf of a domain. It builds on **SPF** (Sender Policy Framework) and **DKIM** (DomainKeys Identified Mail).
- **How it works:**
 - **Verifies** that the email's SPF and/or DKIM checks pass.
 - **Aligns** the domain in the "From" address with those used in SPF/DKIM.
 - **Applies a policy** (e.g., none, quarantine, reject) based on the domain owner's DMARC record.
 - **Sends reports** to the domain owner about email authentication activity.
- Benefits: Reduce email spoofing, protect reputation, and improves email deliverability and trust.

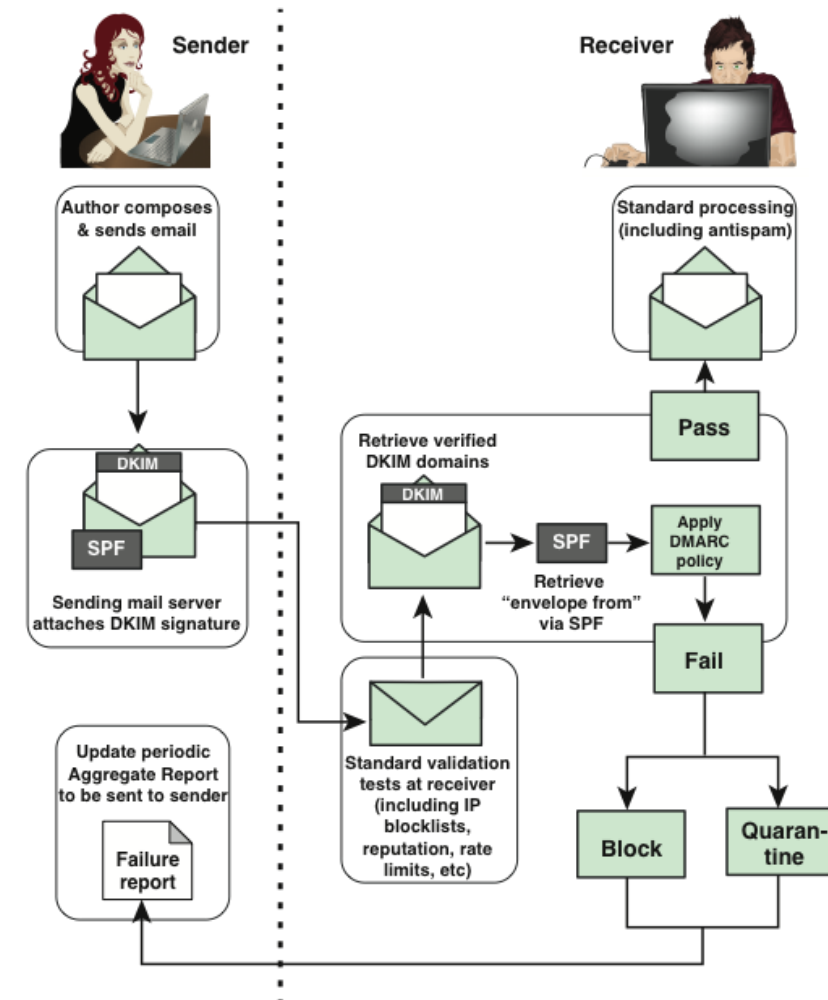
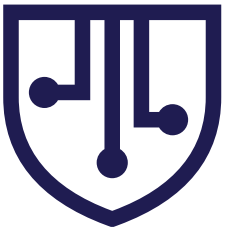
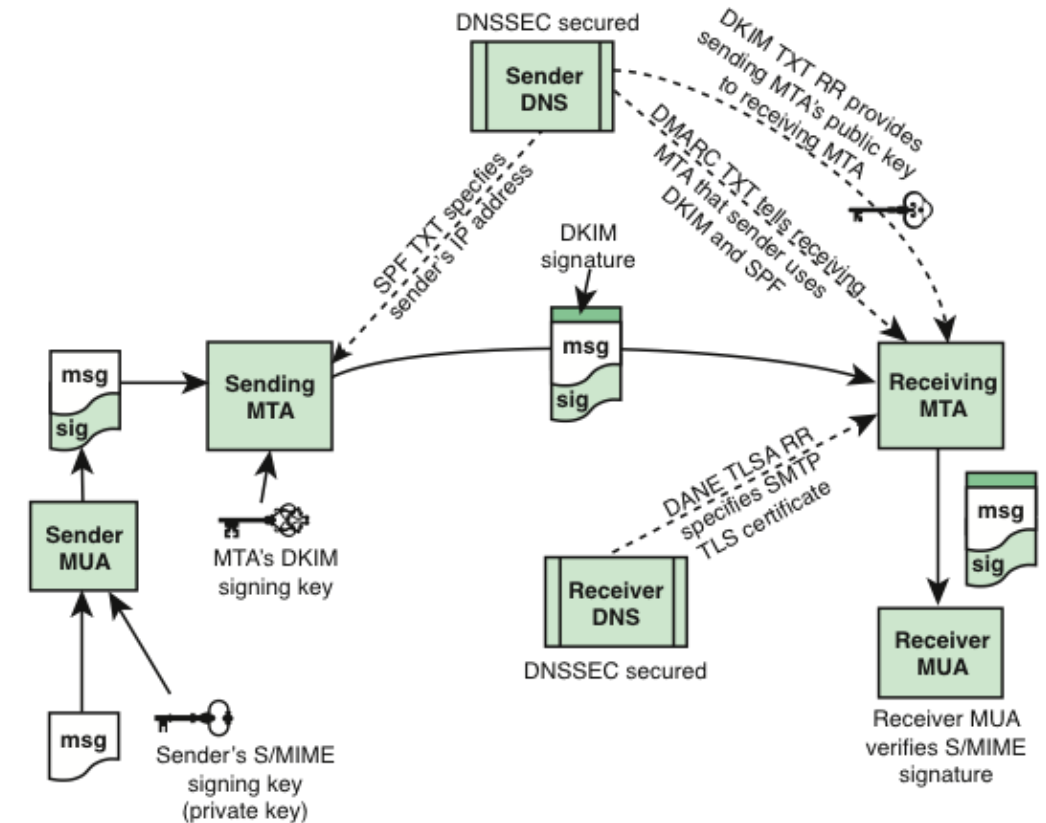


Figure 19.12 DMARC Functional Flow

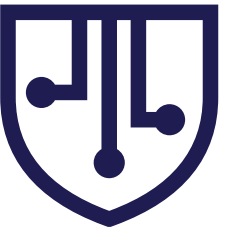


The Interrelationship of DNSSEC, SPF, DKIM, DMARC, DANE and S/MIME for assuring message authenticity and integrity

Technology	Purpose	Depends On	Common Usage
DNSSEC	Secure DNS data and prevent tampering	DNS infrastructure	Validating DNS records (e.g., DKIM, DANE)
SPF	Verify sending server's IP address	DNS (TXT record)	Authorizing legitimate mail servers
DKIM	Ensure message integrity and sender identity	DNS (public key in TXT)	Signing emails for authenticity
DMARC	Enforce email policy and provide feedback	SPF, DKIM	Blocking spoofed emails
DANE	Bind TLS certificates via DNS	DNSSEC	Securing SMTP over TLS
S/MIME	Encrypt and sign email content	CA-issued certificates	End-to-end email security in enterprises



DANE = DNS-based Authentication of Named Entities
DKIM = DomainKeys Identified Mail
DMARC = Domain-based Message Authentication, Reporting, and Conformance
DNSSEC = Domain Name System Security Extensions
SPF = Sender Policy Framework
S/MIME = Secure Multi-Purpose Internet Mail Extensions
TLSA RR = Transport Layer Security Authentication Resource Record



Summary

- Internet mail architecture
- E-mail formats
- E-mail threats and comprehensive e-mail security
- Pretty good privacy
- DomainKeys Identified Mail
- S/MIME
- DNSSEC
- DNS-based authentication of named entities
- Sender policy framework
- DomainKeys identified mail

THANKS – Q&A



zulhilmi_abd@yahoo.com



<https://www.researchgate.net/profile/Zul-Abdullah>



<https://www.linkedin.com/in/zul-hilmi>